MSE INFORMATION AND NETWORK SECURITY

A Review of Signcryption

Theoretical Advances, Standardization, and the Gap to Practical Deployment

BAHATI Justin · 202540272

MSE 9123 · Dr. Egide Nkurunziza · April 2026

Secure Messaging Requires Three Things

1

Confidentiality

Only the intended recipient can read the message.

2

Authenticity

Receiver is sure the sender is who they claim to be.

3

Non-repudiation

Sender cannot later deny having sent the message.

Traditional approach: Sign-then-Encrypt — *but at what cost?*

The Cost of Sign-then-Encrypt

6

modular exponentiations

Schnorr + ElGamal at 1536-bit

>50%

communication overhead

Ciphertext exceeds half the plaintext length

> “No one had previously questioned whether secure + authenticated delivery *must* cost the sum of signature and encryption separately.” — *Zheng, CRYPTO 1997*

Signcryption: One Operation, Both Goals

Sign-then-Encrypt (StE)

Message m → Sign (sk_A) → Encrypt (pk_B) → **(c, σ)**

6 exponentiations · 2 sequential steps

Signcryption (Zheng, 1997)

Message m → **Signcrypt (sk_A, pk_B)** → **c**

3 exponentiations · single step with shared key exchange

~50% computational savings · **~85%** communication savings

Zheng's Construction (SDSS1)

Signcrypt (m; x_A, y_B)

1. Pick $x \leftarrow Z_q$
   $(k_1, k_2) \leftarrow H(y_B \hat{} x \bmod p)$
2. $c \leftarrow E_{k_1}(m)$
   $r \leftarrow KH_{k_2}(m)$
   $s \leftarrow x / (r + x_A) \bmod q$
3. Return (c, r, s)

Unsigncrypt ((c,r,s); y_A, x_B)

1. $(k_1, k_2) \leftarrow$
   $H((y_A \cdot g \hat{} r) \hat{} \{s \cdot x_B\} \bmod p)$
2. $m \leftarrow D_{k_1}(c)$
3. Accept iff $r = KH_{k_2}(m)$

Key insight: The ephemeral **y_B ^ x** derives the symmetric key *and* binds the signature — one exponentiation does double duty.

From Informal Arguments to Canonical Proofs

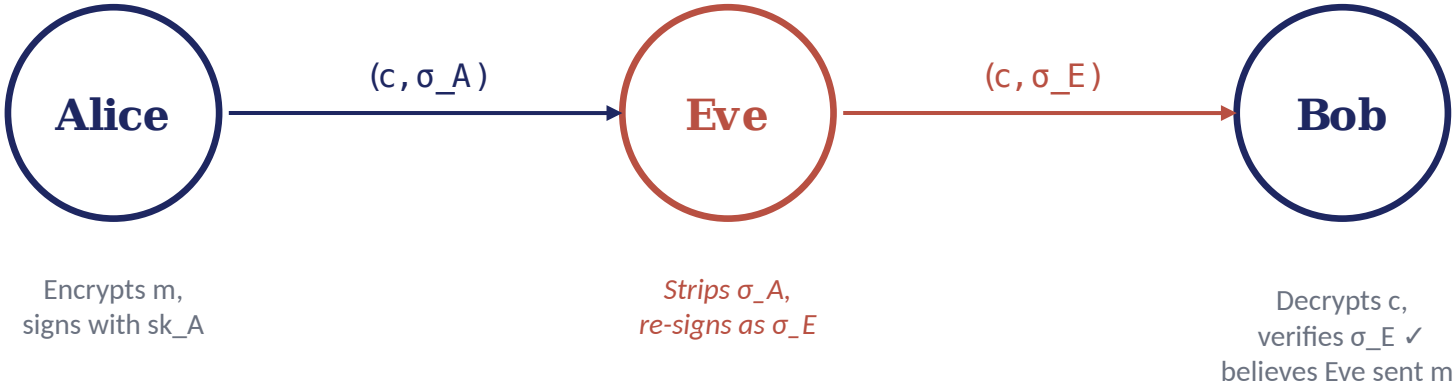
Zheng
1997
Original scheme; only informal security argument

Baek · An
2002
First formal models: IND-CCA2, EUF-CMA (random oracle)

Badertscher
2018
Insider security proved canonical (constructive crypto)

Every classical scheme's proof lives in the **Random Oracle Model** — an idealization that does not hold in practice.

Why Naive Composition Fails: The EtS Attack



Signcryption isn't just StE optimized — it provides qualitatively different security.

ID-Based Signcryption: A Cautionary Tale

2002

Malone-Lee

First IBSC scheme using bilinear pairings (BDH)

2003

Libert & Quisquater

Flaw found: signature exposed in clear → semantic security defeated

2003

Boyen (IBSE)

Adds anonymity, unlinkability, forward secrecy

Pattern: integrating signature + encryption is subtle; flaws surface only under formal analysis.

ISO/IEC 29150 (2011): Formal Recognition

DLP-based family

From Zheng's original SDSS1/SDSS2
over finite fields

EC-based family

From Zheng–Imai (1998)
over elliptic curves

Two operating modes for each family:

Key transport Fresh symmetric key generated and transmitted alongside ciphertext

Key agreement Symmetric key derived from shared Diffie–Hellman computation

⚠ Unlike AES or SHA-3, ISO/IEC 29150 shipped without reference implementations or industry champions. **No major library ships a conforming implementation.**

Scheme Comparison at a Glance

Scheme	Year	Setting	Hardness	Proof Model	vs StE
Zheng	1997	PKI	DLP	—	50% / 85%
Zheng–Imai	1998	PKI (EC)	ECDLP	—	58% / 40%
Steinfeld–Zheng	2000	PKI	Factoring	ROM	Similar
Baek et al.	2002	PKI	GDH / DLP	ROM	Same as Zheng
An et al.	2002	PKI	Generic	ROM	Compositional
Malone-Lee	2002	ID-based	BDH	ROM	Fewer pairings
Boyen	2003	ID-based	BDH	ROM	Compact
Sato–Shikata	**2018**	**PKI**	**LWE / SIS**	**Standard**	**Under study**

Only one scheme — Sato–Shikata (2018) — is proved secure in the **standard model**; every classical construction depends on the ROM.

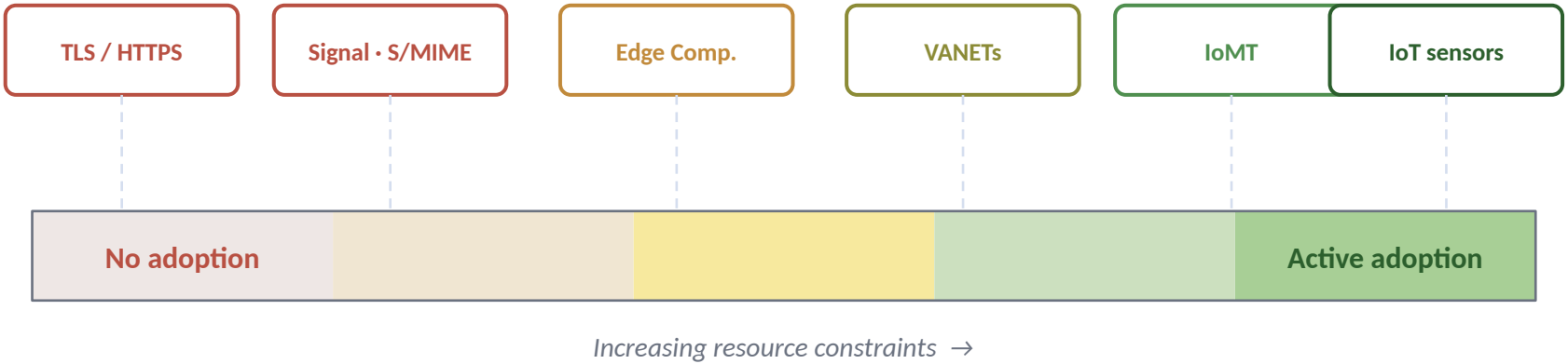
The Central Puzzle: Why No Adoption?

Despite ISO/IEC 29150, **no** major cryptographic library implements signcryption. **No** widely deployed protocol uses it.

1	2	3	4	5
Ecosystem Inertia	**Modularity**	**AEAD & Hardware**	**Security-Model Complexity**	**Post-Quantum Uncertainty**
Stack optimized for separate primitives	Coupling sig + enc kills algorithm agility	AES-NI erased the efficiency margin	Insider/outsider, CCA2 variants — subtle	Classical assumptions fall to Shor

Thesis: *the deployment failure is fundamentally a* ***security-model communication failure*** *— no crisp answer for "what does this buy me beyond ECDH + ECDSA?"*

Adoption Follows Resource Constraint



Adoption tracks the efficiency margin.
Where AES-NI and hardware-accelerated ECDSA run, signcryption is unnecessary.
Where every byte and joule matters — IoT, IoMT, VANETs — it becomes operationally decisive.

Research Gaps Ordered by Dependency

FOUNDATIONAL

1

Post-Quantum Signcryption

All classical assumptions fall to Shor

2

Standard-Model Proofs

Replace ROM reductions with real ones

DOWNSTREAM

3. **Library Implementations** — Conforming ISO/IEC 29150 reference
4. **Protocol Integration** — TLS, DTLS, CoAP cipher suites
5. **Lightweight IoT Builds** — Side-channel-resistant MCU code
6. **Key Escrow (CLC)** — Certificateless variants, pairing-free
7. **Multi-Receiver Scale** — Broadcast with PQ ciphertext sizes

Foundational challenges (1–2) block progress on everything downstream.

Conclusion

01

Theoretically mature.

Formal proofs, identity-based variants, ISO standardization — all in place.

02

Practically absent from mainstream.

Not in OpenSSL, not in TLS. AEAD + ECDH ate the efficiency advantage.

03

Bridging the gap.

Post-quantum constructions, standard-model proofs, reference libraries.

Thank you · Questions?